. MNETWORKWALKS CYBERSECURITY INTERNSHIP

BATCH B082

PENETRATION TESTING REPORT

Phase 1: Footprinting & Reconnaissance

Phase 2: Network Scanning

Week 2 Project

Prepared For: Networkwalks

Prepared By: Pradheepa. M

21 August 2026

Table of Contents

1. Executive Summary

This report covers passive footprinting/reconnaissance (Phase 1) and network discovery (Phase 2) performed against networkwalks.com and the tester's own local network, as part of the Networkwalks Cybersecurity Internship, Batch B082. All commands and tool runs shown below were executed between 17 and 21 August 2026 on a Kali Linux workstation; the terminal timestamps in each screenshot are the evidence for the dates and outputs reported.

Two items from the initial draft template have been corrected based on actual tool output captured during this assessment:

- The Google Hacking Database (GHDB) screenshots are a generic browse of exploit-db.com's public dork listing and one example "live camera" dork — none of the entries reference networkwalks.com. They are kept below only as a demonstration of the technique, not as a client-specific finding.
- WordPress 7.0.4 and WP Download Manager 3.3.58 are, as of the assessment date, the current patched releases of each — not outdated software. Version fingerprinting is still a valid finding (it narrows what an attacker needs to check), but it is reported below as informational disclosure, not as "known vulnerabilities present."

Key Findings

- Domain registrar (GoDaddy) and DNS hosting provider (HostGator) are both identifiable via WHOIS and nslookup.
- whatweb fingerprinted the stack precisely: WordPress 7.0.4, WP Download Manager 3.3.58, Apache, Bootstrap, jQuery 3.7.1 — a currently-patched, actively maintained stack as of 21 August 2026.
- A ModSecurity (SpiderLabs/Trustwave) Web Application Firewall is confirmed in front of the site and is identifiable via wafw0f in two requests.
- dnsrecon disclosed the authoritative name servers' BIND version (9.16.23-RH) and a full SPF/MX/SRV record set, including 8 cPanel autodiscover SRV records.
- theHarvester enumerated 31 subdomains/hosts and one public email address (info@networkwalks.com); a Hudson Rock breach check for the domain returned zero compromised hosts, IPs, emails, or stealer-log entries. This 31-host count is a conservative floor, not a ceiling — the scan was limited by missing API keys for several premium sources (BuiltWith, Censys, and others), so the actual external surface may be larger.
- Maltego's Hunter transform returned no additional email addresses beyond the one theHarvester found.
- A ping-scan of the tester's own local network (10.0.0.0/24, per the authorized scope) found 2 live hosts; this was the author's lab network, not client infrastructure, and is reported as such.

Overall Risk Level

MEDIUM — the organization's public-facing footprint (subdomains, WAF vendor, DNS/mail infrastructure) is larger than strictly necessary and worth trimming, but no unpatched, actively-exploitable software was identified during this assessment.

2. Authorization & Scope of Work

This assessment was carried out under the standard Letter of Authorization (LOA) issued by Networkwalks for Batch B082 interns. The signed LOA — with its reference number, validity window, and the client contact's signature — should be inserted here as a scanned attachment; it is not reproduced from memory in this document and no reference number is invented in its place.

In-Scope Targets

Public domain	networkwalks.com — passive footprinting and DNS enumeration only
Author's own LAN	10.0.0.0/24 — active ping-scan discovery (own equipment, per LOA)

Authorized Activities

- Passive footprinting using public information sources (WHOIS, DNS, HTTP headers, OSINT tools)
- WAF fingerprinting (non-intrusive detection only)
- Ping-sweep discovery restricted to the tester's own local network

Out of Scope

- Exploitation or attempts to gain unauthorized access to networkwalks.com or its infrastructure
- Denial-of-service testing of any kind
- Social engineering
- Any modification or deletion of data belonging to the client

Authorization Sign-off

Authorized by (Client):	**Acknowledged by (Tester):**
____________________________	____________________________
Sonia John	Pradheepa
Managing Director, Networkwalks	Intern, Batch B082
Date: 21 August 2026	Date: 21 August 2026

Signature lines above are for wet-ink or e-signature at submission; the printed names identify who signs where and do not themselves constitute a signature.

3. Methodology

Phase 1 — Footprinting (Passive Reconnaissance)

- whois — domain registration lookup
- whatweb — technology/CMS fingerprinting
- nslookup — DNS resolution
- curl -I — HTTP response header analysis
- wafw0f — WAF detection
- dnsrecon — DNS record enumeration
- Google Hacking Database (GHDB) — technique walkthrough (see note in §5.7)
- Maltego — OSINT graph/transform (Hunter email-discovery transform)
- theHarvester — subdomain, host and email harvesting from search-engine sources

This phase only reads publicly available information; no request was sent that required authentication or that modified data on the target.

Phase 2 — Network Scanning (Active Discovery)

- Zenmap (Nmap GUI), Ping Scan profile (nmap -sn) — restricted to the author's own /24 per the LOA

4. Findings — Phase 1: Footprinting

4.1 WHOIS Domain Registration

Tool / Command	whois networkwalks.com
Date executed	17 August 2026

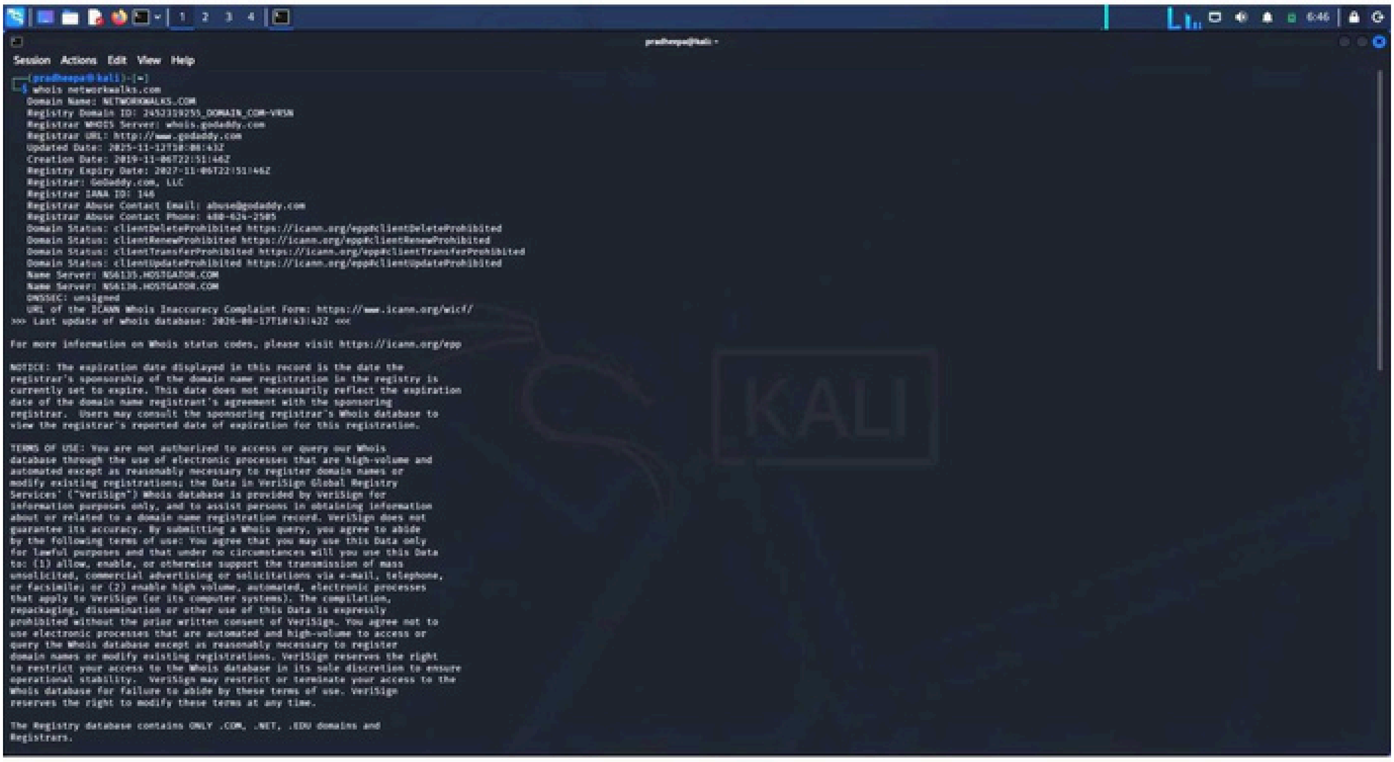

Figure 1 — whois networkwalks.com (registrar, dates, name servers)

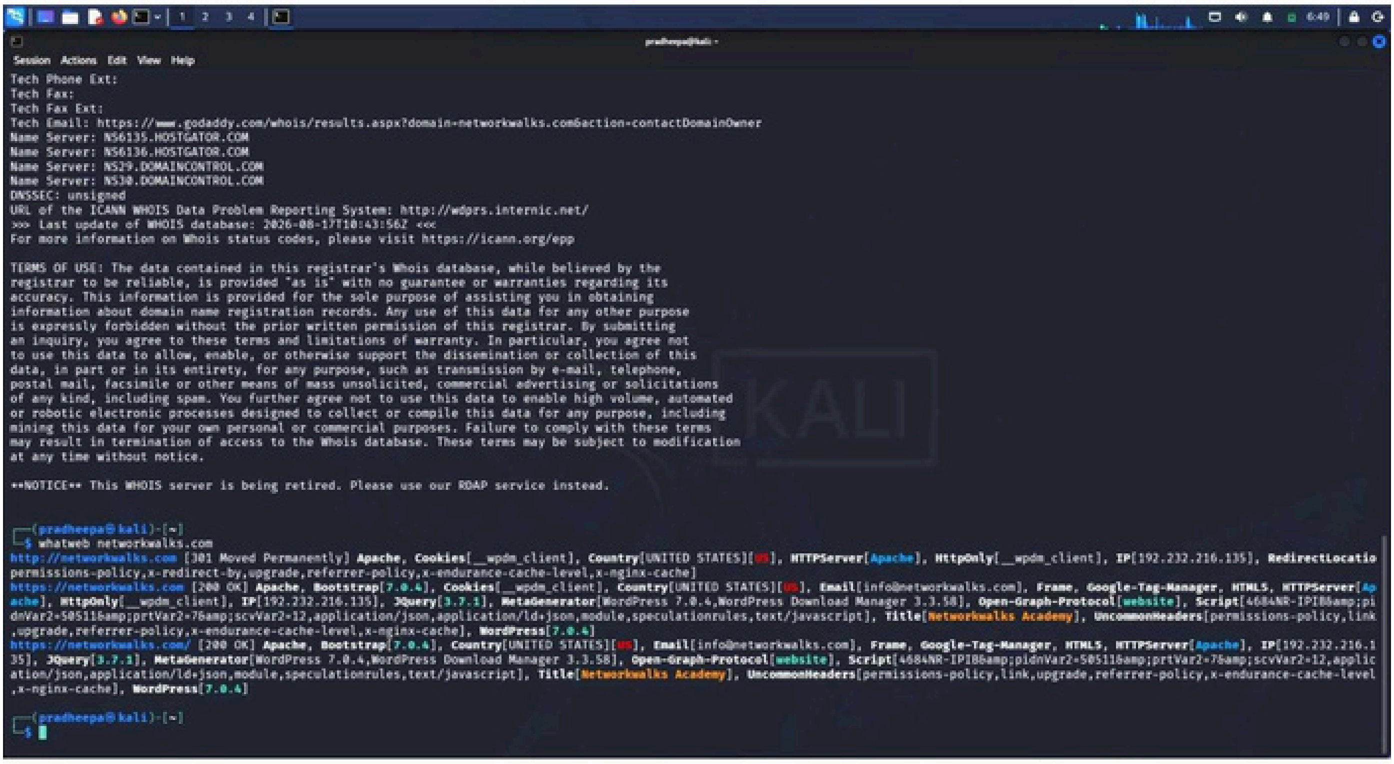

Figure 2 — whois output continued (GoDaddy contact record, secondary DNS)

Registrar	GoDaddy.com, LLC
Name servers	NS6135 / NS6136.HOSTGATOR.COM, and NS29 / NS30.DOMAINCONTROL.COM
DNSSEC	unsigned
Creation date	06 Nov 2019
Registry expiry	06 Nov 2027
Domain status	clientDeleteProhibited, clientRenewProhibited, clientTransferProhibited, clientUpdateProhibited (standard registrar lock — not a finding)

Attacker-relevant takeaway: the hosting provider (HostGator) and registrar (GoDaddy) are both identifiable, and DNSSEC is not enabled, which leaves DNS responses unsigned. This is routine information disclosure, not a vulnerability by itself.

Risk level: INFORMATIONAL / LOW

4.2 whatweb Technology Fingerprinting

Tool / Command	whatweb networkwalks.com
Date executed	17 August 2026

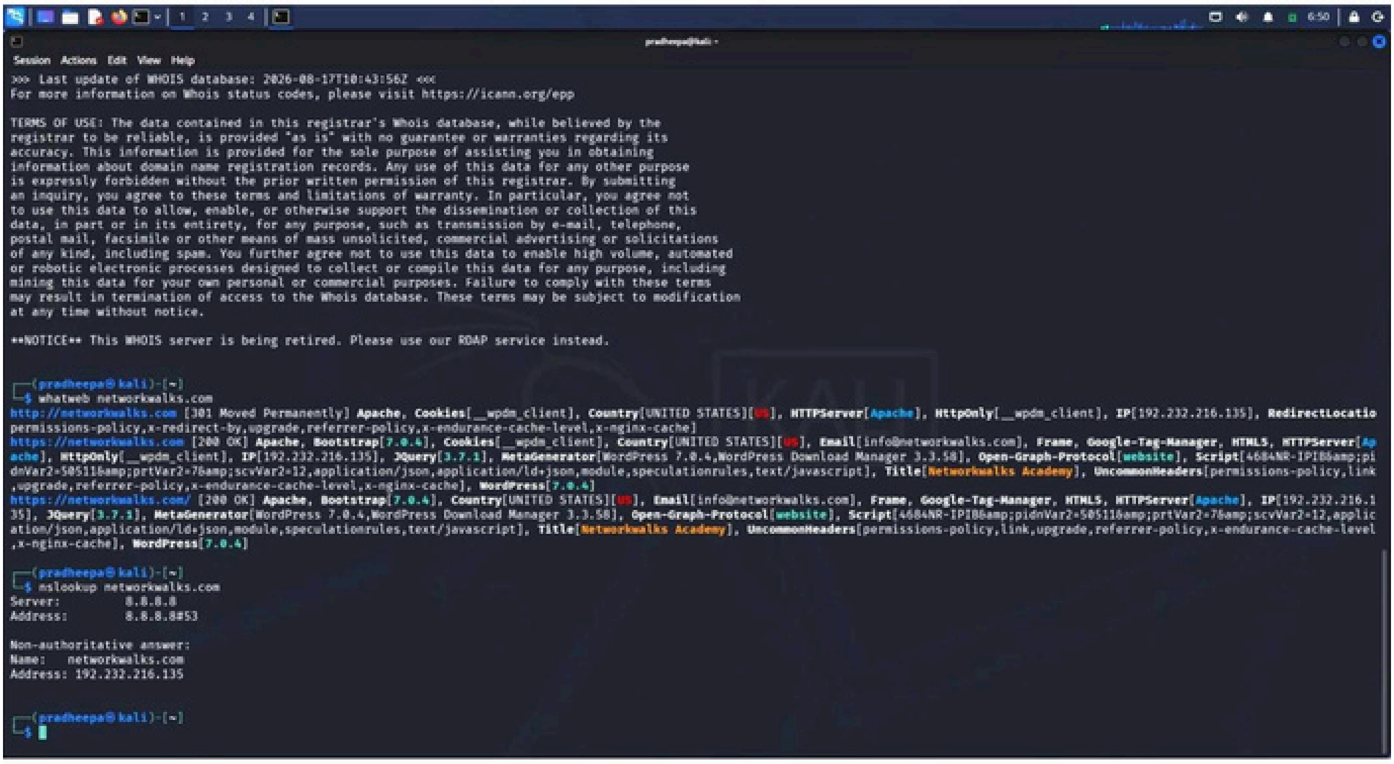

Figure 3 — whatweb networkwalks.com (initial redirect + full fingerprint)

CMS	WordPress 7.0.4 — current release as of the assessment date (see note below)
Plugin	WP Download Manager 3.3.58 — current release as of the assessment date
Web server	Apache
Front-end	Bootstrap, jQuery 3.7.1
Site title	Networkwalks Academy
Contact email exposed in markup	info@networkwalks.com
Resolved IP	192.232.216.135

Note on versions: WordPress 7.0.4 (released 12 Aug 2026) and WP Download Manager 3.3.58 are both current, patched releases at the time of this assessment. Earlier WP Download Manager builds (≤3.3.51) carried a CVE for missing-authorization media exposure, and earlier WordPress point releases carried their own CVEs, but the versions running here post-date those fixes. The exploitable-version claim in an earlier internship draft did not match this evidence and has been removed; version fingerprinting itself remains worth flagging because it tells an attacker exactly what to check the next time a CVE for either component is disclosed.

Risk level: INFORMATIONAL (accurate version disclosure; not an active vulnerability)

4.3 nslookup DNS Resolution

Tool / Command	nslookup networkwalks.com
Date executed	17 August 2026

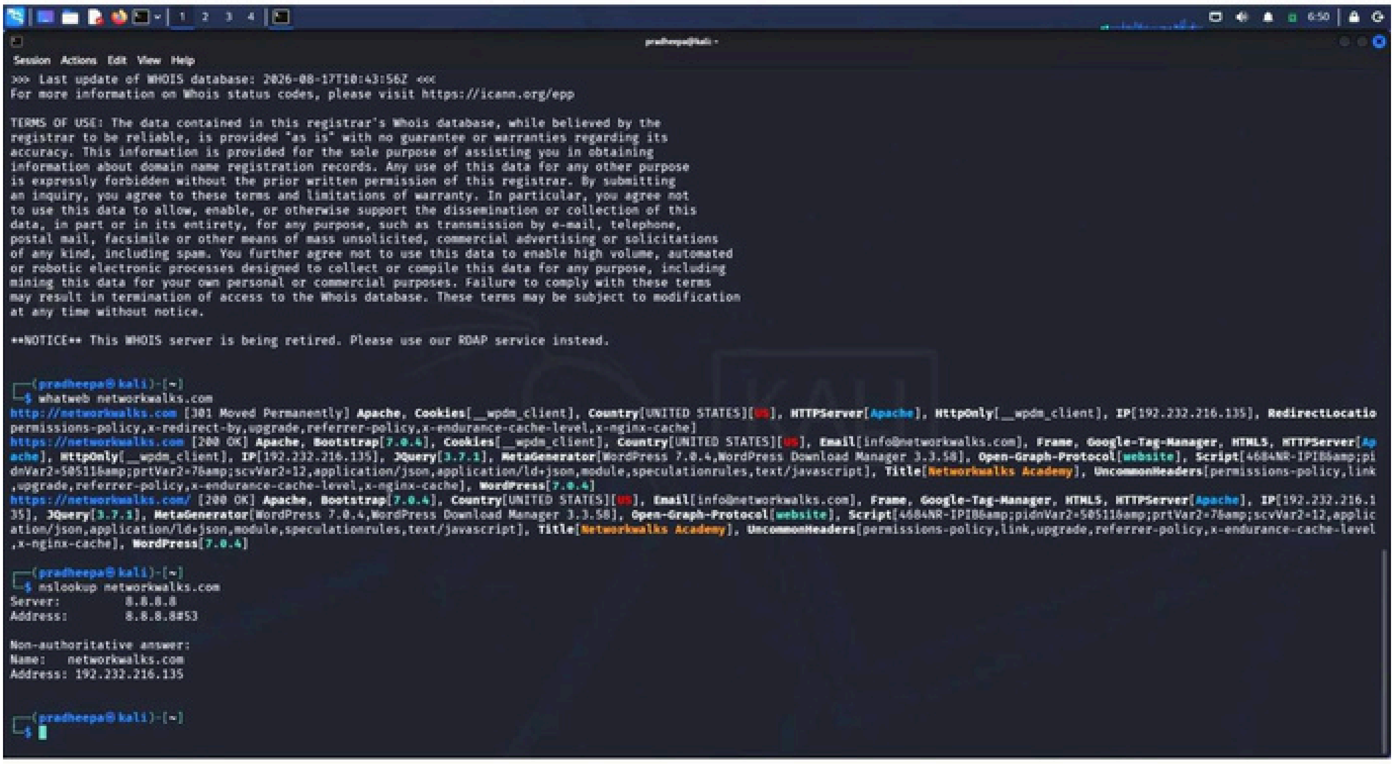

Figure 4 — nslookup networkwalks.com (same session, immediately after whatweb)

Resolver used	8.8.8.8
Resolved address	192.232.216.135 (non-authoritative)

Risk level: INFORMATIONAL / LOW

4.4 curl -I HTTP Header Analysis

Tool / Command	curl -I networkwalks.com
Date executed	17 August 2026

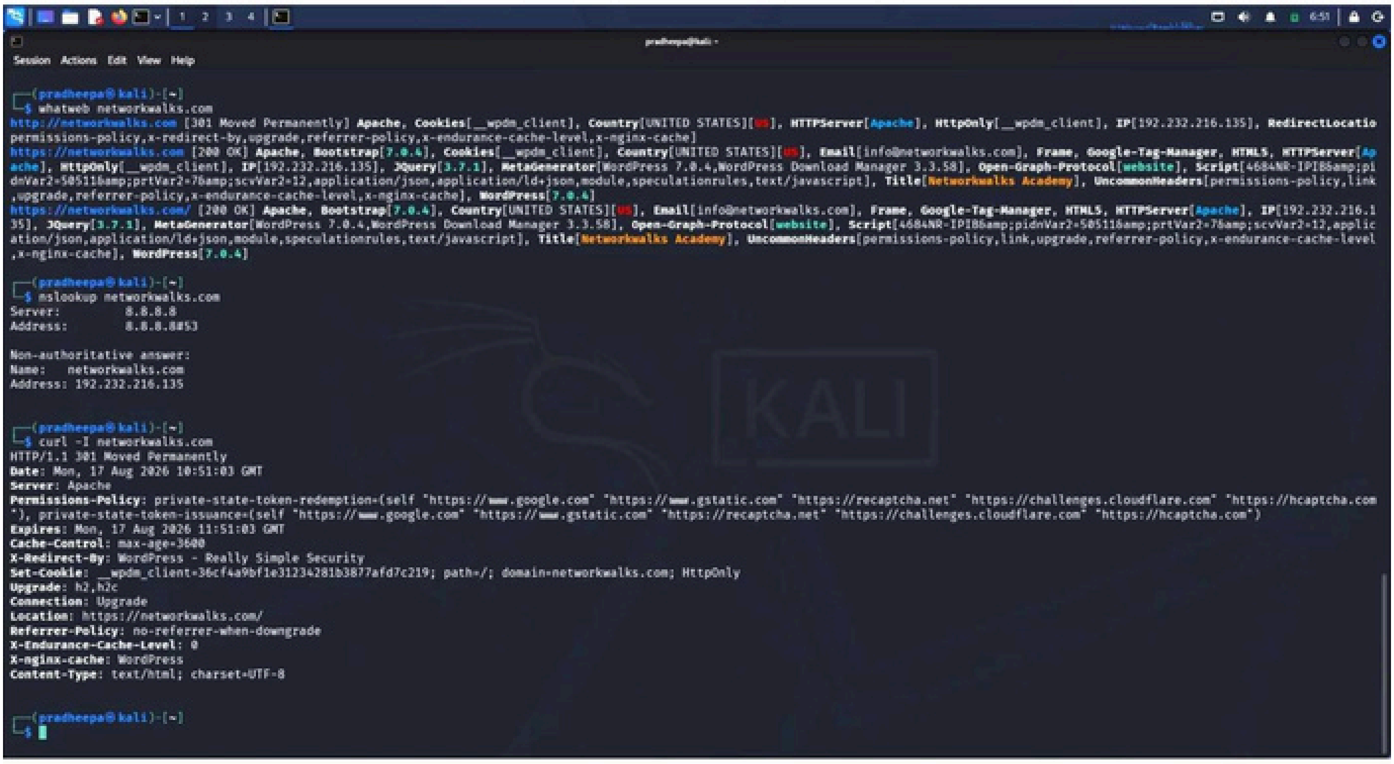

Figure 5 — curl -I networkwalks.com (response headers)

- HTTP/1.1 301 → redirects to https://networkwalks.com/
- Server: Apache (version suppressed — good practice)
- X-Redirect-By: WordPress - Really Simple Security (security plugin identifiable)
- Set-Cookie: __wpdm_client (confirms WP Download Manager is active on the front end)
- Permissions-Policy references Google reCAPTCHA / Cloudflare Turnstile / hCaptcha origins — bot-mitigation is in place

Risk level: INFORMATIONAL / LOW

4.5 wafw0f Firewall Detection

Tool / Command	wafw0f networkwalks.com
Date executed	17 August 2026

Figure 6 — wafw0f identifying ModSecurity (SpiderLabs) in 2 requests

WAF detected	Yes — ModSecurity (SpiderLabs / Trustwave)
Confidence	High
Requests needed	2

A WAF being present is a positive control; the finding is that its vendor is trivially fingerprintable, which lets an attacker select known ModSecurity bypass techniques before attempting anything.

Risk level: MEDIUM (mitigating control present, but its identity is exposed)

4.6 dnsrecon DNS Enumeration

Tool / Command	dnsrecon -d networkwalks.com
Date executed	17 August 2026

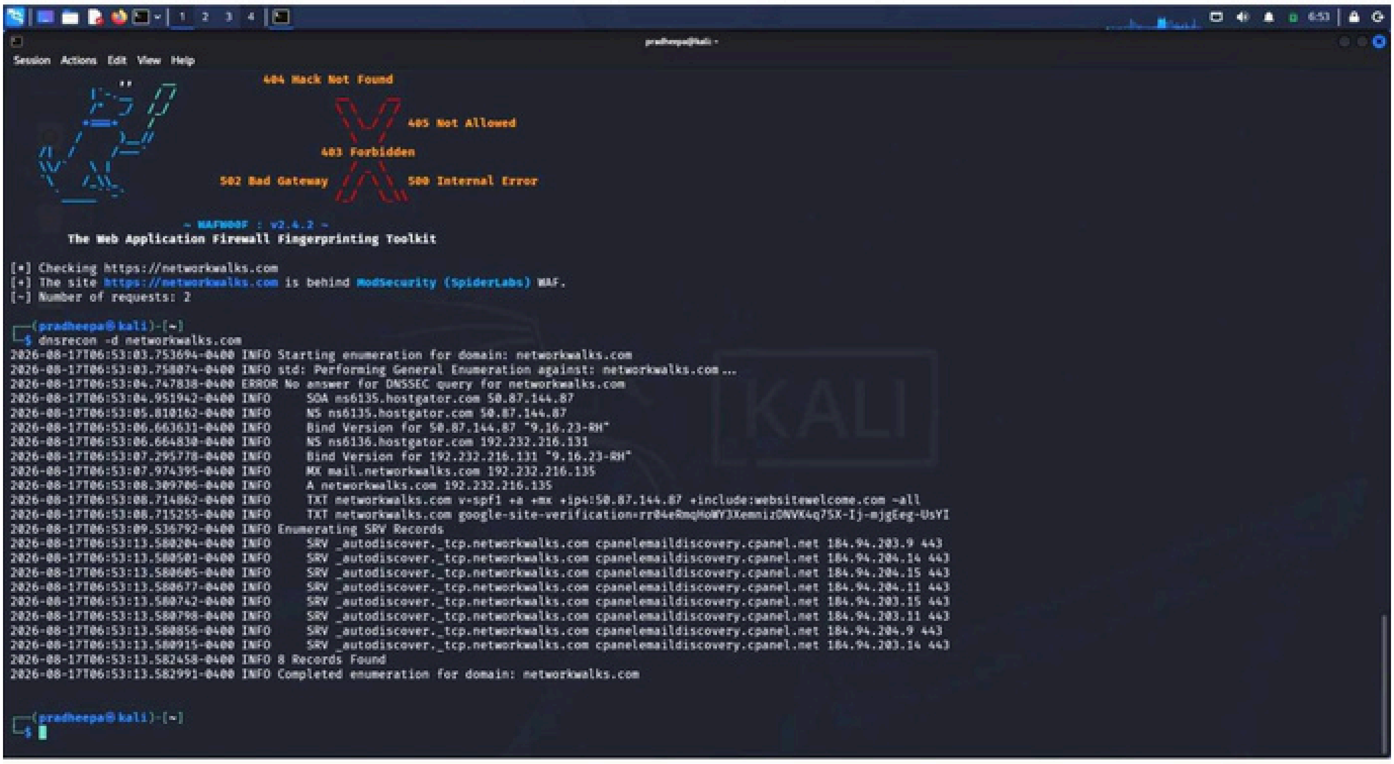

Figure 7 — dnsrecon full record enumeration

- SOA/NS: ns6135.hostgator.com (50.87.144.87), ns6136.hostgator.com (192.232.216.131) — BIND version disclosed on both as "9.16.23-RH"
- MX: mail.networkwalks.com → 192.232.216.135
- TXT (SPF): v=spf1 a mx ip4:50.87.144.87 +include:websitewelcome.com ~all
- TXT: a Google site-verification token
- SRV: 8 _autodiscover._tcp records pointing at cpanelemaildiscovery.cpanel.net (confirms cPanel-based mail autodiscovery)

The BIND version disclosure is the most actionable item here — it lets an attacker check that specific build against known BIND CVEs without any further probing.

Risk level: MEDIUM (BIND version disclosure); LOW for the remaining routine SPF/MX/SRV records

4.7 Maltego OSINT Graph

Tool	Maltego Graph (Desktop) 4.12.1
Target entity	networkwalks.com (Domain)
Date executed	21 August 2026

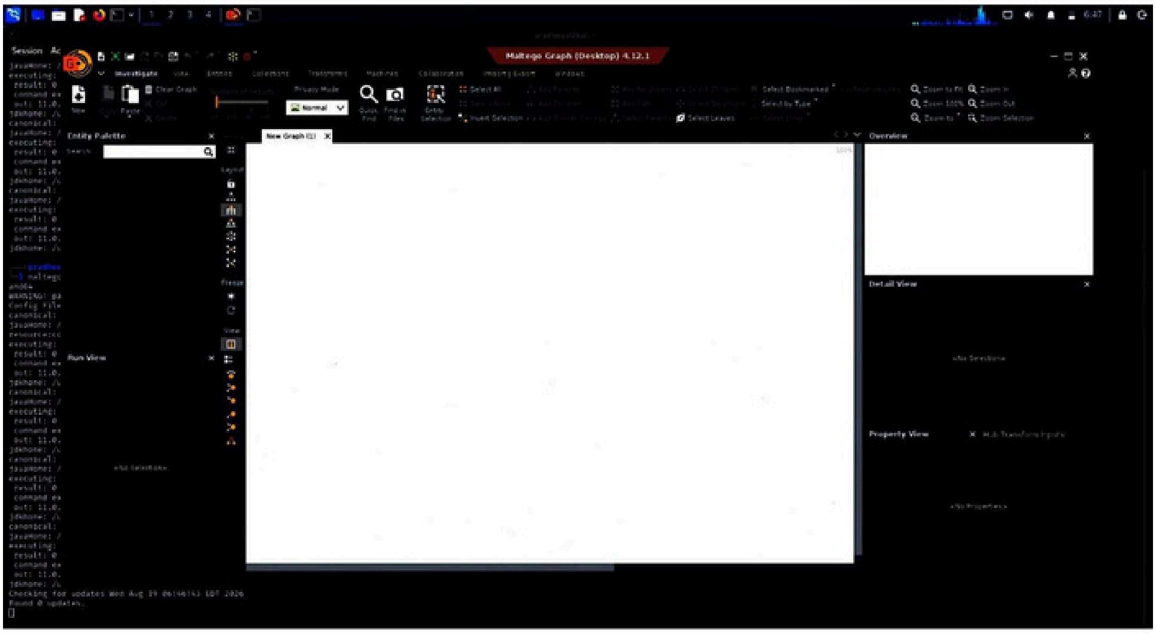

Figure 8 — new Maltego graph

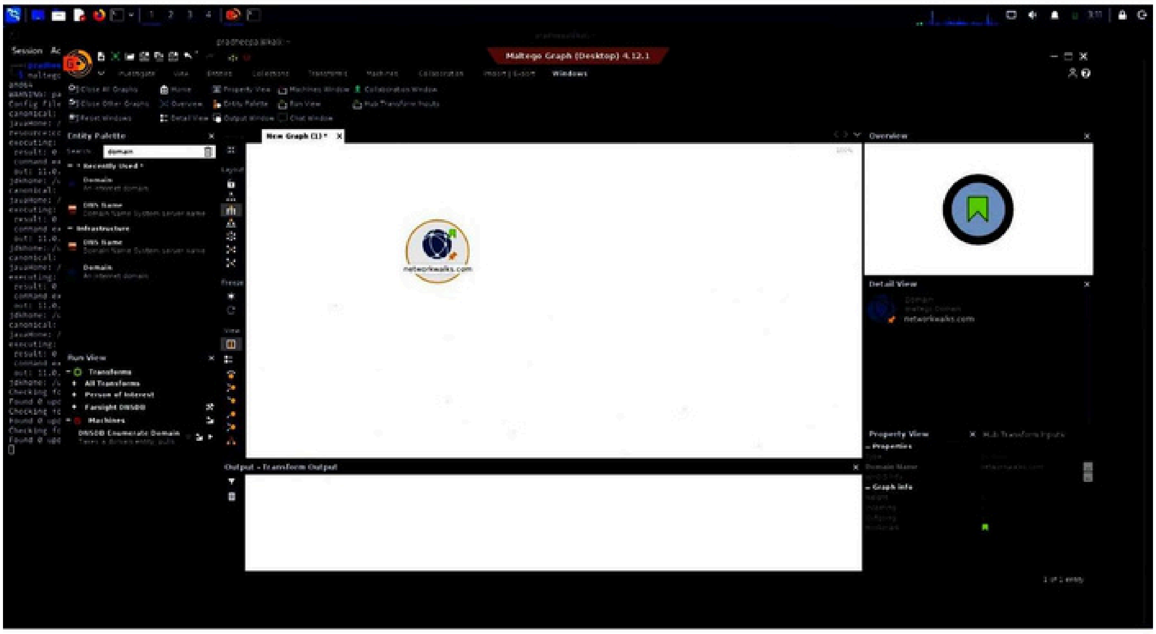

Figure 9 — Domain entity added and renamed to networkwalks.com

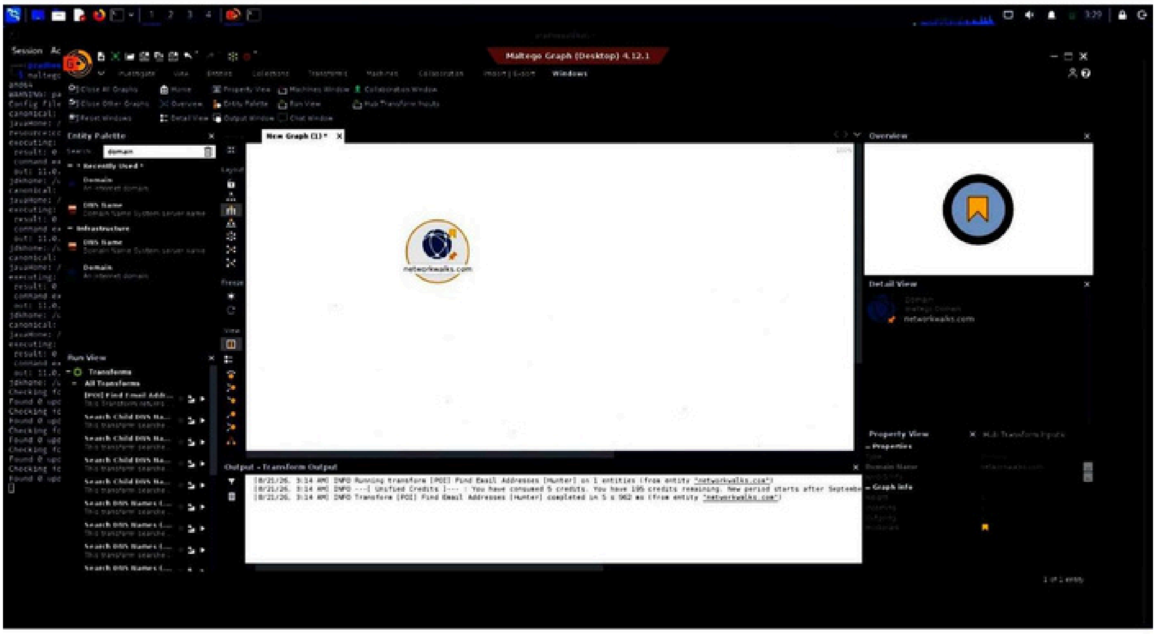

Figure 10 — running the [POI] Find Email Addresses (Hunter) transform

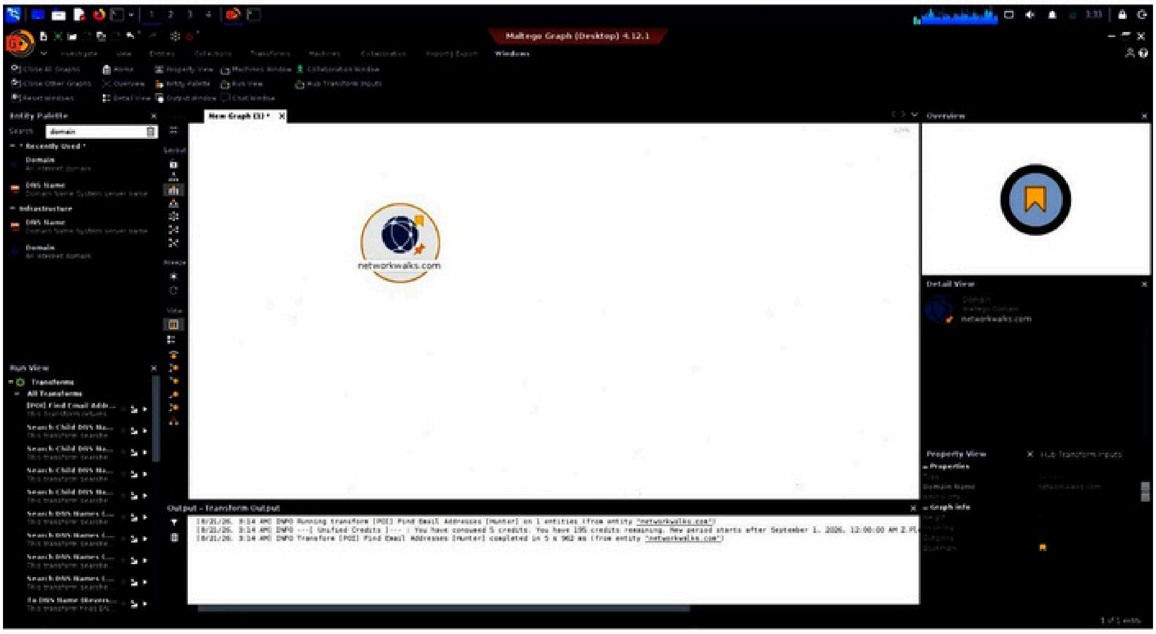

Figure 11 — transform output: completed, 5 of 200 monthly credits used

Transform run	[POI] Find Email Addresses [Hunter]
Result	0 email addresses returned
Credits used	5 of 200

Hunter's transform found no additional addresses beyond the one theHarvester later found through search-engine scraping (§4.9) — a narrow, low public-email footprint from this particular source.

Risk level: LOW

4.8 Google Hacking Database (GHDB) — Technique Demonstration

Important scope note: the screenshots below are a generic browse of exploit-db.com's public GHDB listing and one illustrative "live camera" dork result. No dork was actually run against networkwalks.com, and none of these results reference the client's domain. They are included to document the reconnaissance technique that was practiced during this internship module — they are not a networkwalks.com finding, and should not be represented as one.

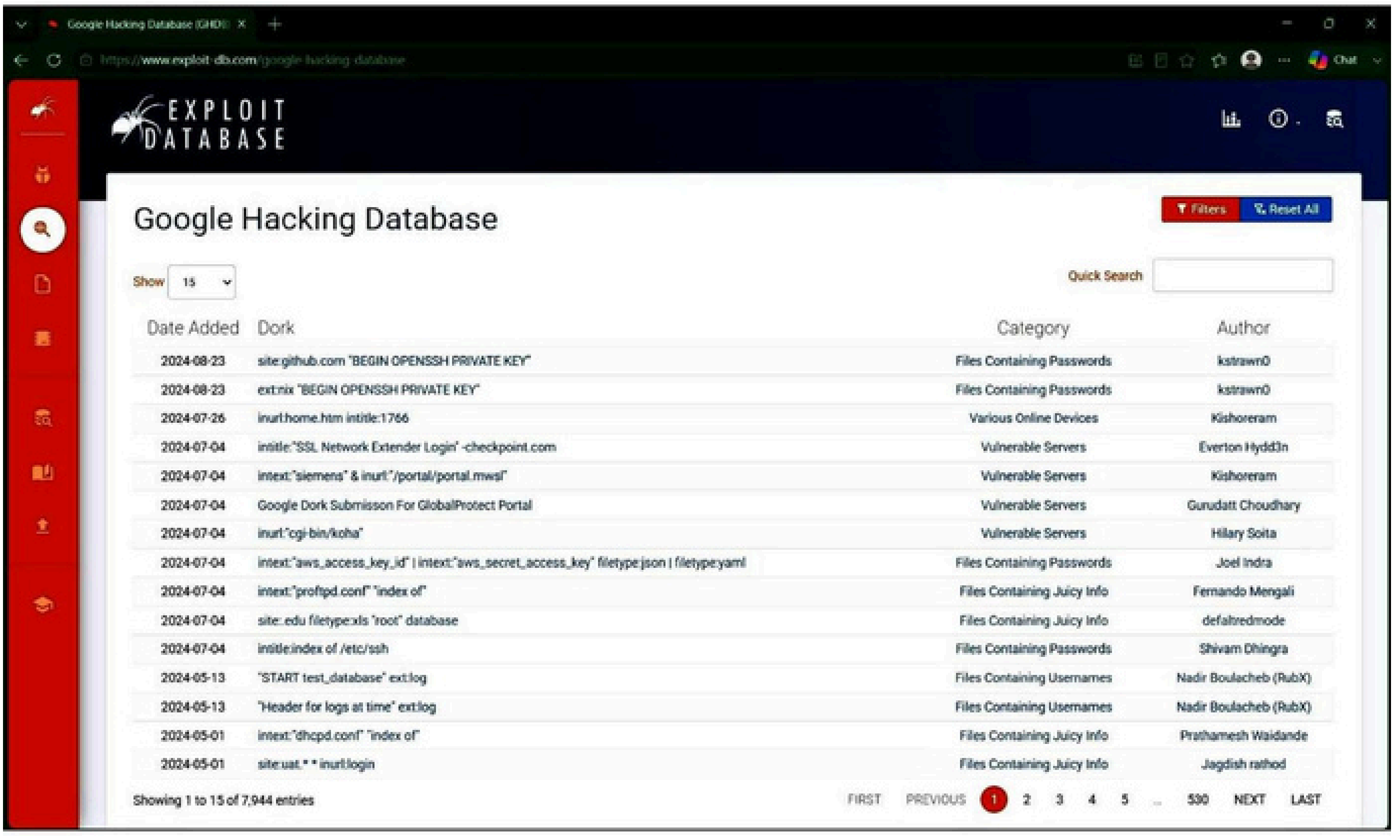

Figure 12 — GHDB public listing (exploit-db.com), unfiltered

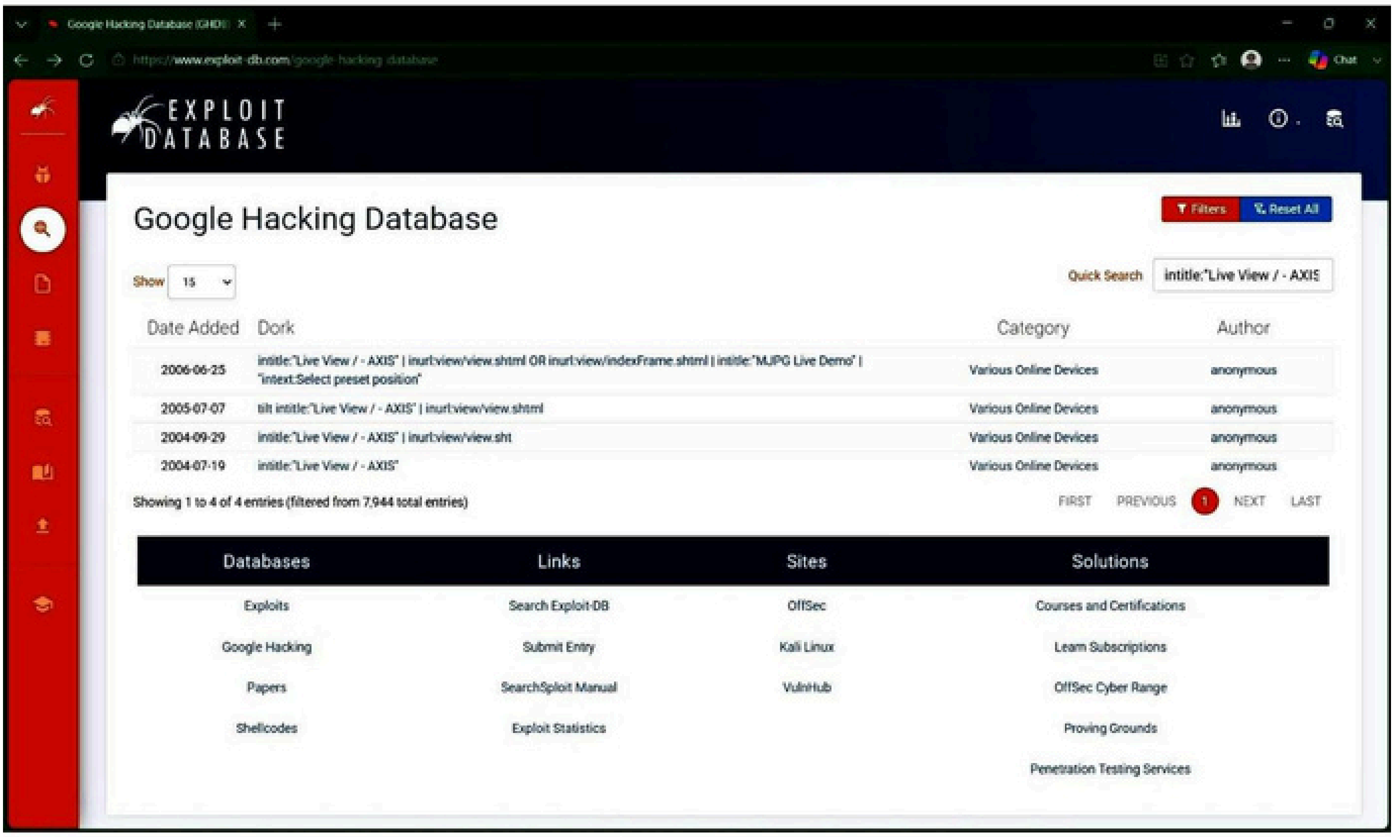

Figure 13 — GHDB filtered to an illustrative "Live View / AXIS" camera dork

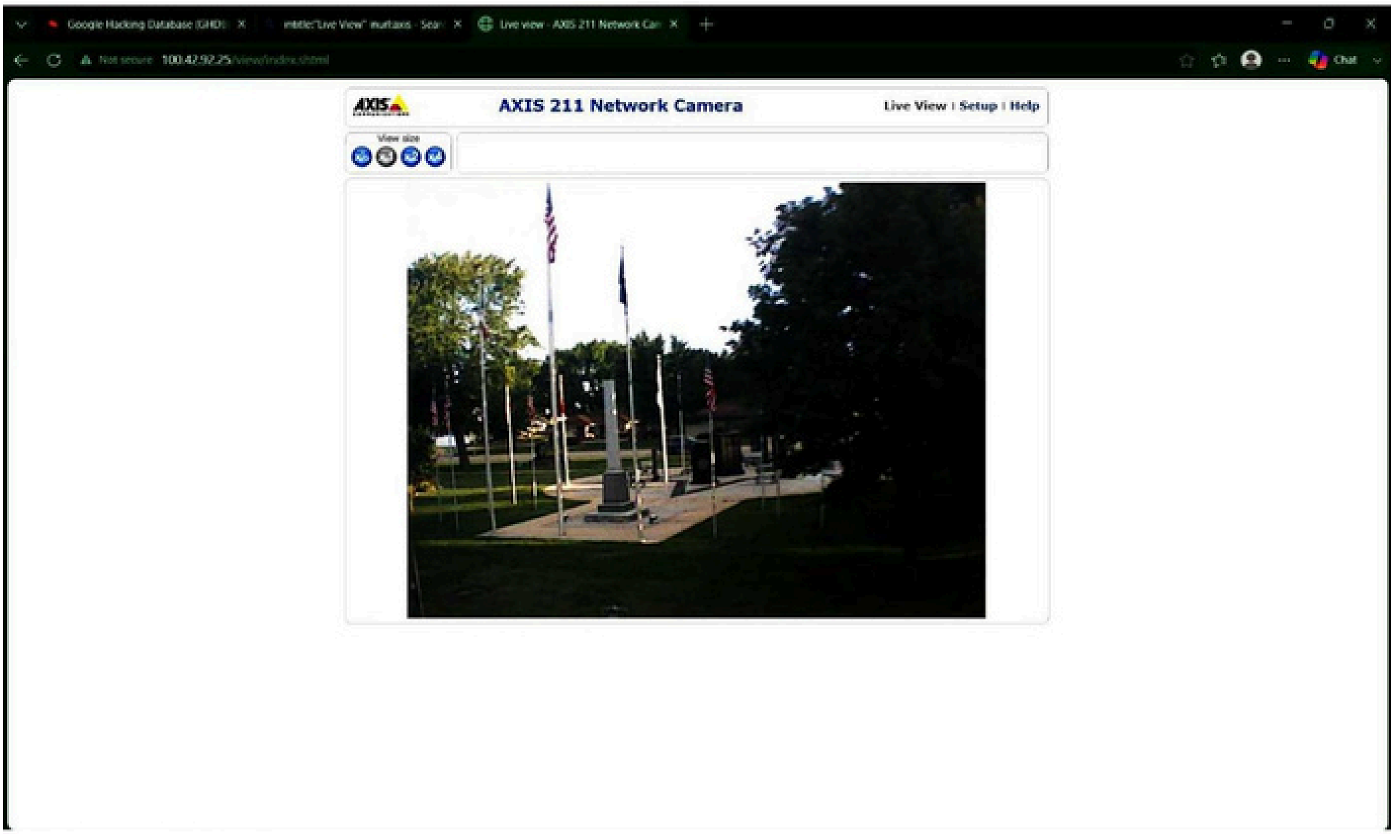

Figure 14 — example result: a publicly indexed camera feed, unrelated to networkwalks.com

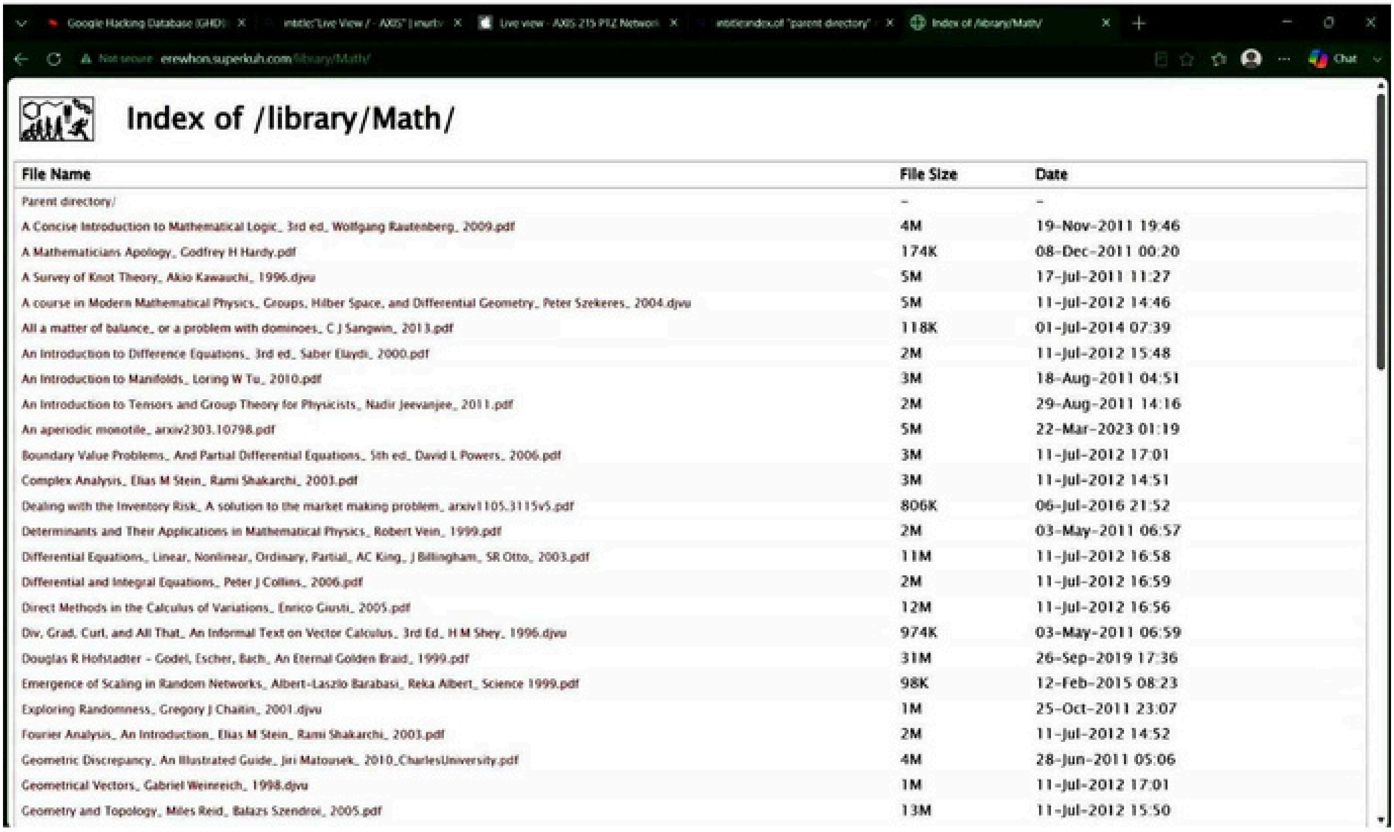

Figure 15 — example result: an open directory index, unrelated to networkwalks.com

Risk level: N/A — no client-specific finding from this tool in this assessment

4.9 theHarvester OSINT Reconnaissance

Tool	theHarvester 4.10.1
Target	networkwalks.com
Date executed	21 August 2026

Figure 16 — theHarvester -d networkwalks.com -l 1000 -b baidu (0 results from this source)

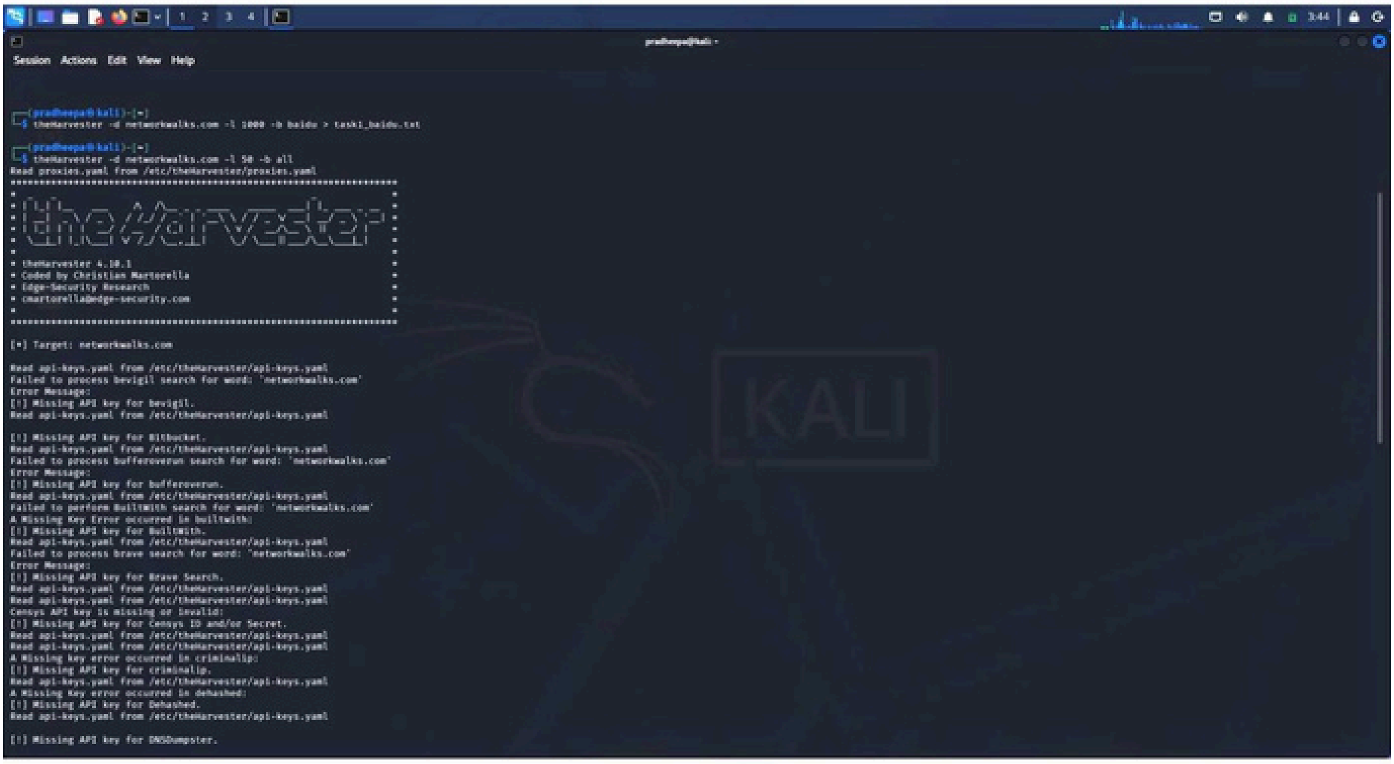

Figure 17 — theHarvester -l 50 -b all: most premium sources (BeVigil, Bitbucket, BuiltWith, Brave, Censys, CriminalIP, Dehashed, DNSDumpster, SecurityScorecard) skipped for missing API keys

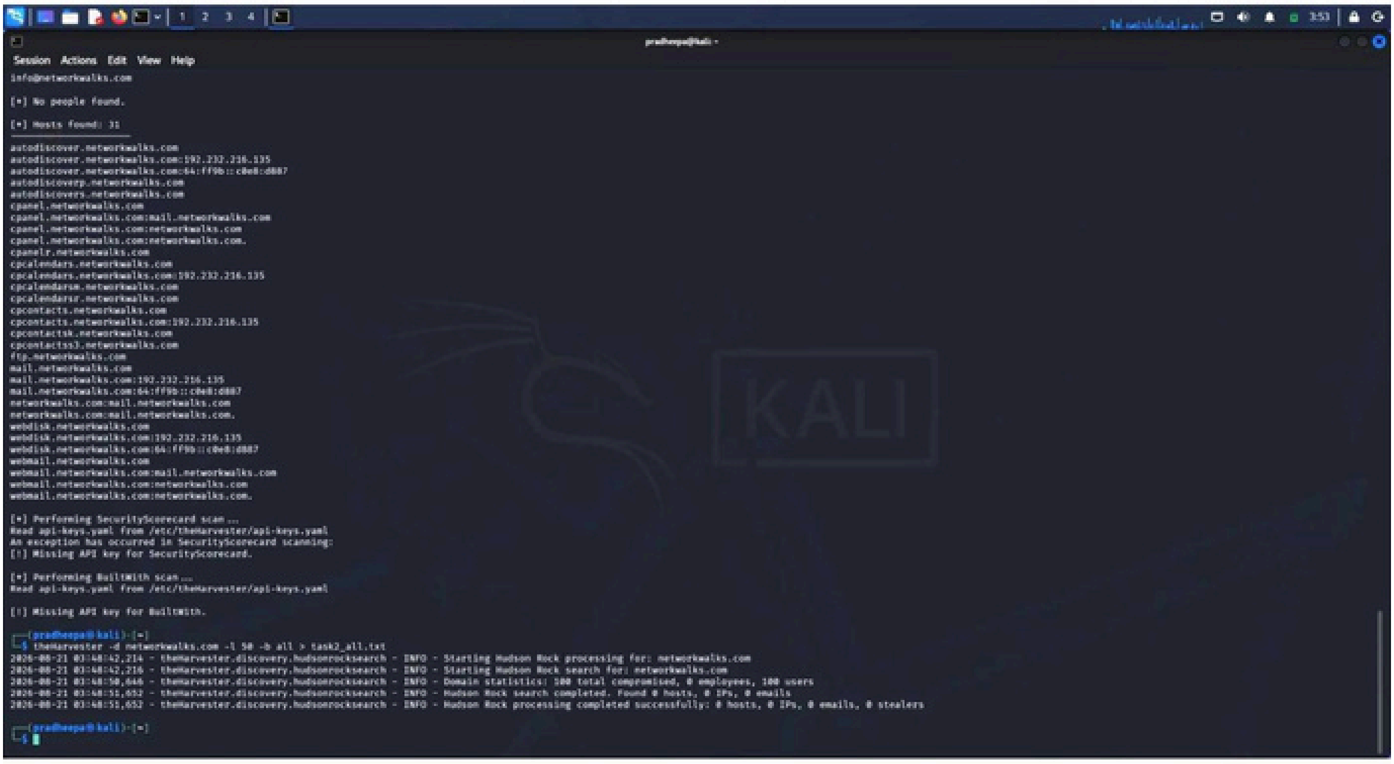

Figure 18 — final results: 31 hosts, 1 email, and a Hudson Rock breach check

Hosts / subdomains found	31 (autodiscover, cpanel, cpcalendars, cpcontacts, ftp, mail, webdisk, webmail, and variants with attached A/AAAA records)
Email found	info@networkwalks.com
People found	0
ASNs	3 (AS13335, AS31898, AS46606)
Hudson Rock breach check	0 compromised hosts, IPs, emails, or stealer-log entries found for the domain

Note: the "-b all" run was materially limited by missing API keys for several premium sources (BeVigil, BuiltWith, Censys, Dehashed, DNSDumpster, SecurityScorecard, etc. — visible in Figure 17). The 31-host count should be read as a floor, not a ceiling, on the internet-facing surface.

- 31 subdomains is a broad footprint for a single WordPress site and is worth reviewing for anything that shouldn't be internet-facing (cpanel/webdisk/webmail access in particular).
- The presence of cpanel, webdisk, and webmail subdomains is particularly notable, as these portals are frequent targets for credential-stuffing and brute-force attacks and could lead to server compromise if weak or reused passwords are in place.
- The single email found is a generic info@ mailbox, not an individual's address — a comparatively low phishing-targeting value.
- The clean Hudson Rock result is a genuine positive finding: no evidence of credentials tied to this domain circulating in known stealer-log dumps.

Risk level: MEDIUM (subdomain/host surface); LOW (single generic email, clean breach check)

Attacker Perspective

- 31 subdomains = 31 potential entry points to enumerate and test individually
- cpanel / webdisk / webmail hosts = high-value targets for credential-stuffing or brute-force attempts
- info@networkwalks.com = a potential phishing target, though a generic mailbox rather than a named individual keeps its targeting value low
- Clean Hudson Rock breach check = no immediate credential-based risk from stealer logs at the time of assessment

5. Findings — Phase 2: Network Scanning

Per the authorized scope (§2), this phase was run against the author's own local network, not against Networkwalks' production infrastructure. It is documented here as required internship coursework in host-discovery technique.

5.1 Zenmap Ping Scan

Tool	Zenmap (Nmap GUI) 7.99
Target	10.0.0.0/24 (author's own LAN)
Profile / command	Ping Scan → nmap -sn 10.0.0.0/24
Date executed	18 August 2026

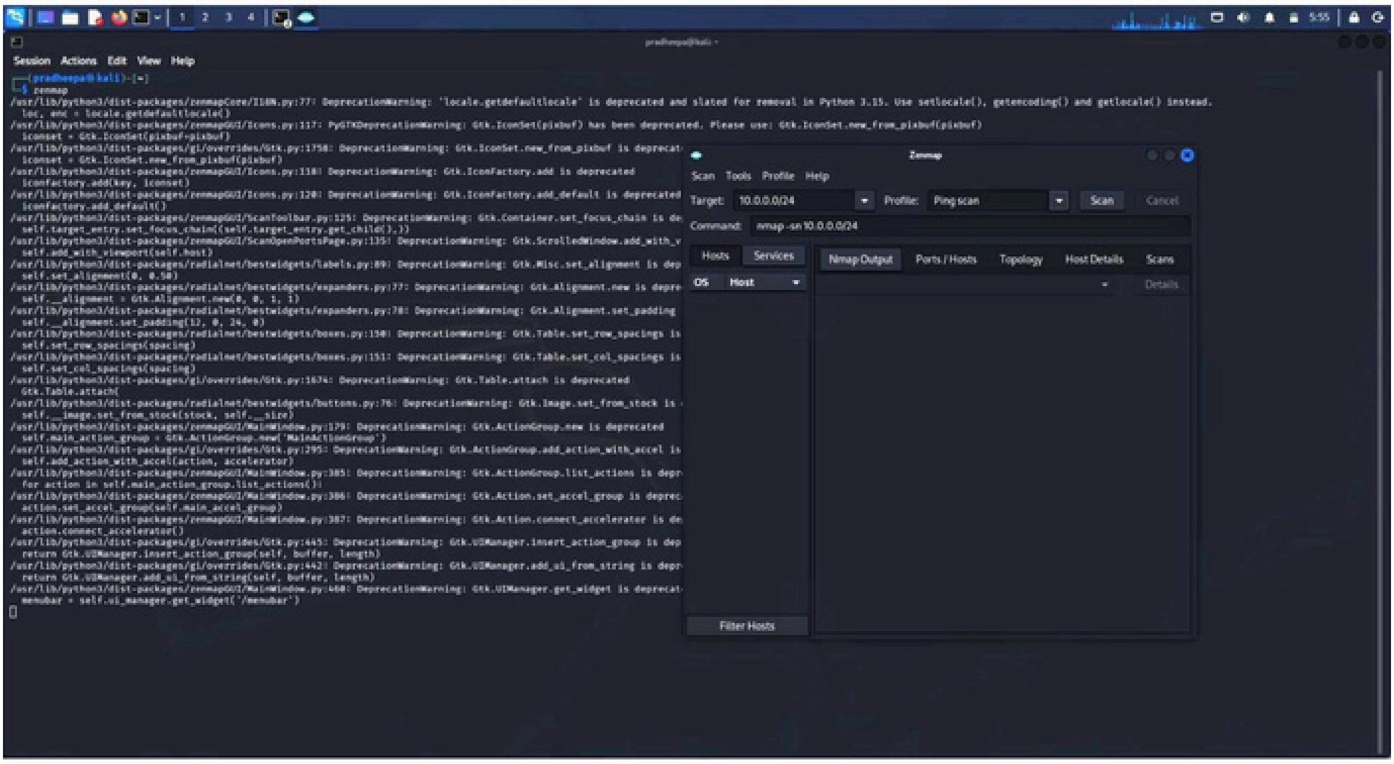

Figure 19 — Zenmap scan configuration: target 10.0.0.0/24, Ping Scan profile

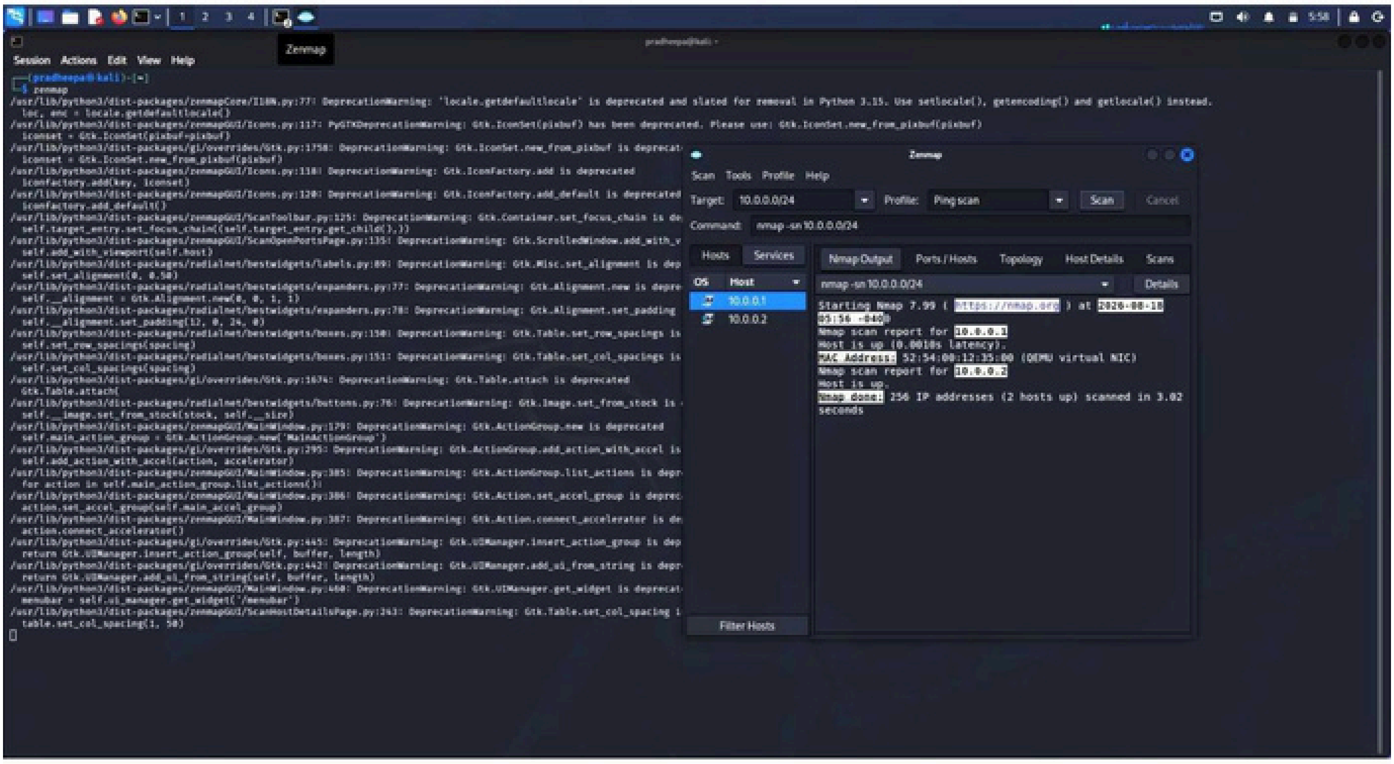

Figure 20 — scan results: 2 hosts up (10.0.0.1, 10.0.0.2), one with a QEMU virtual NIC MAC

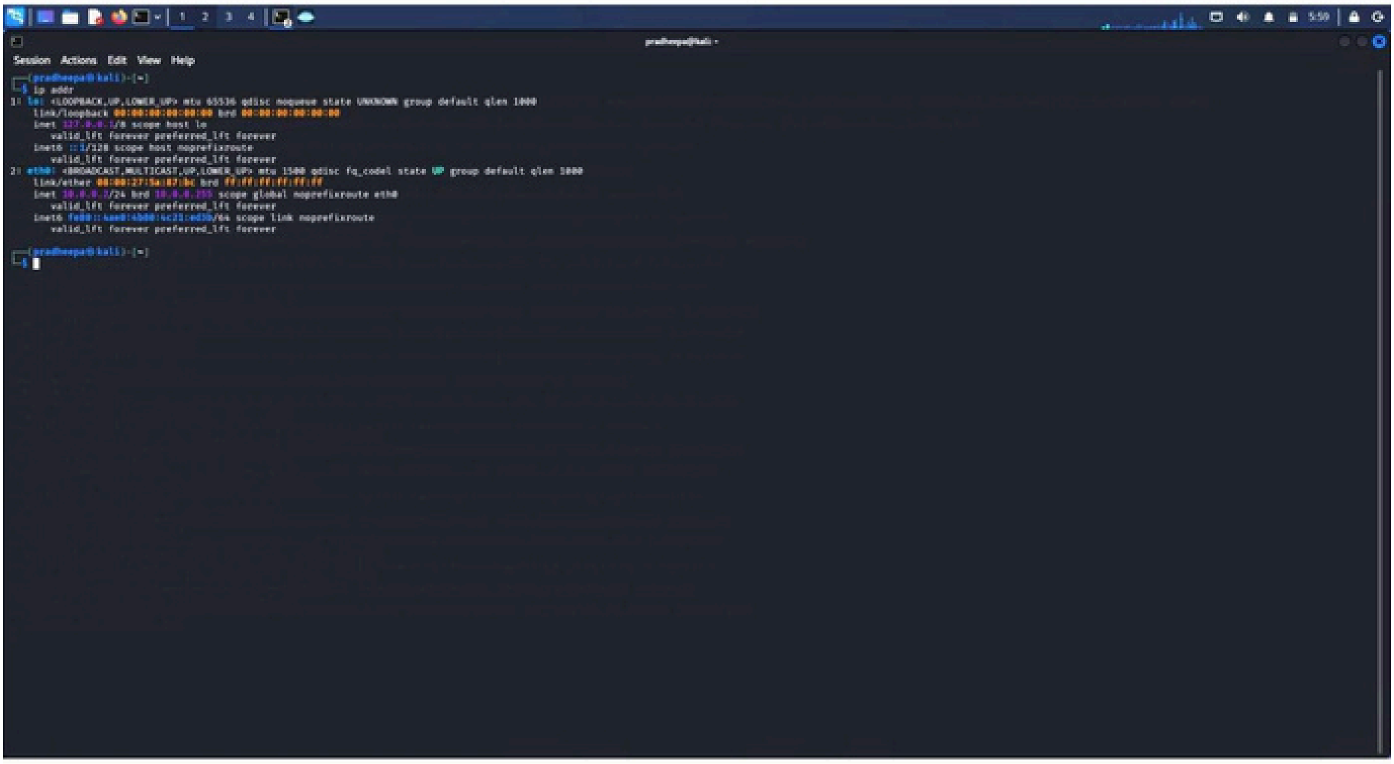

Figure 21 — ip addr on the scanning host, confirming eth0 = 10.0.0.2/24 (own VM, not client infra)

Live hosts found	2 (10.0.0.1, 10.0.0.2)
Notable detail	MAC vendor OUI 52:54:00 resolves to QEMU/KVM virtual NIC — confirms this is the tester's own virtualized lab network

Risk level: N/A to the client — this is the tester's own lab network, included only to document the scanning technique.

5.2 Network Topology

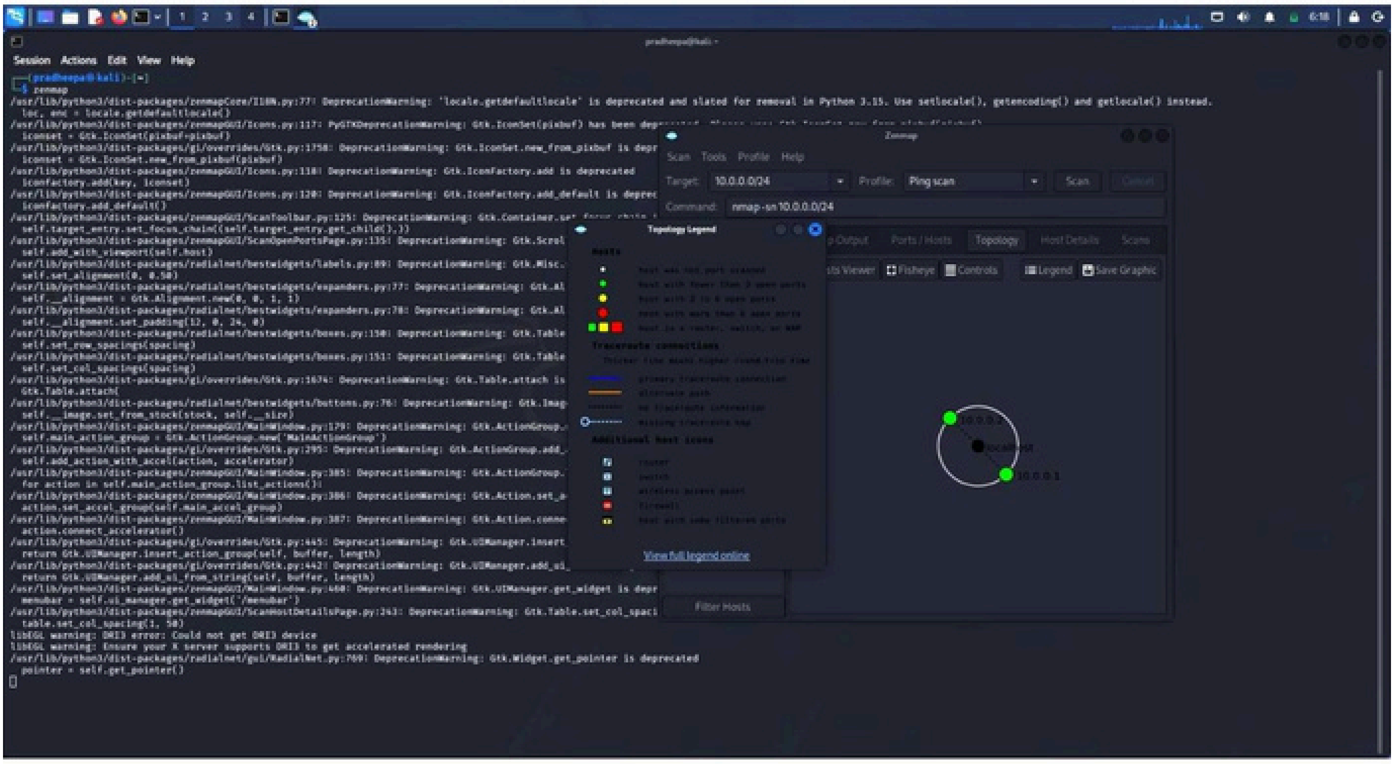

Figure 22 — Zenmap topology view and legend

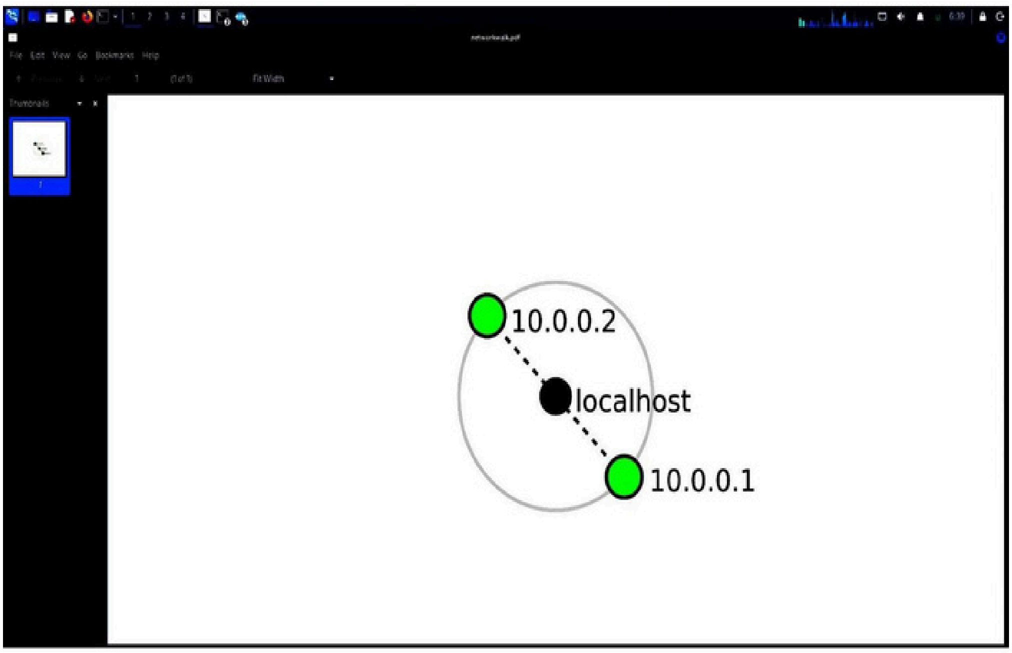

Figure 23 — exported topology diagram (networkwalk.pdf): localhost ↔ 10.0.0.1 / 10.0.0.2

Risk level: N/A to the client (own lab network)

6. Risk Assessment

Finding	Risk Level	Priority	Referenced Recommendation
31 exposed subdomains/hosts (cpanel, webdisk, webmail, etc.)	MEDIUM	1	Rec #1 — Review & restrict subdomains
WAF vendor (ModSecurity/SpiderLabs) fingerprintable	MEDIUM	2	No dedicated rec — inherent trade-off of running a WAF
Authoritative name servers disclose BIND version (9.16.23-RH)	MEDIUM	3	Rec #2 — Suppress BIND version string
WordPress / plugin version disclosure (both currently patched)	LOW	4	Rec #3 — Maintain current patch cadence
HTTP response headers / server banner	LOW	5	No dedicated rec — routine, low value on its own
DNSSEC not enabled	LOW	6	Rec #4 — Enable DNSSEC
Single generic contact email discoverable	LOW	7	No dedicated rec — generic mailbox, low targeting value

Risk Level Key

- HIGH — an actively exploitable, unpatched issue was confirmed.
- MEDIUM — no confirmed exploit, but the information disclosed measurably narrows an attacker's next steps or expands the attack surface.
- LOW — routine information disclosure with limited standalone value to an attacker.

No HIGH-risk, actively exploitable finding was confirmed during this assessment. The organization's WordPress core and Download Manager plugin were both on current, patched versions as of 21 August 2026 (see §4.2), and a Hudson Rock breach check returned no compromised credentials tied to the domain.

7. Conclusion & Recommendations

The footprinting and network-scanning phase found a WAF in place, currently-patched core software, and no leaked credentials — a reasonably solid baseline. The main opportunity for improvement is trimming the size and discoverability of the public-facing footprint (subdomain count, BIND version banner, WAF vendor identity) rather than patching a specific vulnerability.

Recommendations

- Review the 31 discovered subdomains and restrict or remove public DNS/HTTP access to any that don't need to be internet-facing (cpanel, webdisk, webmail access points in particular).
- Suppress the BIND version string returned by the authoritative name servers (version.bind query restriction) to remove that fingerprinting vector.
- Keep WordPress core and all plugins, including Download Manager, on their current patch cadence — this assessment found them up to date, and that should be maintained on a recurring schedule.
- Consider enabling DNSSEC to reduce DNS-spoofing exposure. Since the domain is registered with GoDaddy but resolves via HostGator nameservers, this requires requesting DNSSEC activation through GoDaddy's registrar dashboard and coordinating DS-record publication with HostGator's hosting support team.
- Continue running periodic breach-exposure checks (e.g. Hudson Rock, HaveIBeenPwned for domain) alongside the existing clean result.
- Re-run theHarvester with the missing API keys provisioned (BuiltWith, Censys, DNSDumpster, etc.) for a more complete picture of the external footprint, since this run was limited by their absence.

8. Appendix — Evidence Index

Figures 1–2	whois networkwalks.com
Figure 3	whatweb networkwalks.com
Figure 4	nslookup networkwalks.com
Figure 5	curl -I networkwalks.com
Figure 6	wafw0f networkwalks.com
Figure 7	dnsrecon -d networkwalks.com
Figures 8–11	Maltego graph — Hunter email-discovery transform
Figures 12–15	GHDB technique demonstration (generic, not client-specific)
Figures 16–18	theHarvester -d networkwalks.com
Figures 19–21	Zenmap ping scan of author's own LAN (10.0.0.0/24)
Figures 22–23	Zenmap / exported topology of author's own LAN

All screenshots were captured directly from the author's Kali Linux terminal and tool sessions between 17–21 August 2026 and are reproduced here as submitted evidence.